

BloodDonationSystem - Unauthenticated - Post

Generated with  ZAP on Tue 11 Aug 2026, at 21:08:22

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=Medium, Confidence=High \(2\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=High \(1\)](#)
 - [Risk=Low, Confidence=Medium \(2\)](#)

- [Risk=Informational, Confidence=High\(1\).](#)
- [Risk=Informational, Confidence=Medium\(3\).](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://cdn.jsdelivr.net>
- <http://192.168.100.50:5000>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: [User Confirmed](#), [High](#), [Medium](#), [Low](#)

Excluded: [User Confirmed](#), [High](#), [Medium](#), [Low](#), [False Positive](#)

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)	0 (0.0%)
	Medium	0 (0.0%)	2 (18.2%)	2 (18.2%)	0 (0.0%)	4 (36.4%)
	Low	0 (0.0%)	1 (9.1%)	2 (18.2%)	0 (0.0%)	3 (27.3%)
	Informational	0 (0.0%)	1 (9.1%)	3 (27.3%)	0 (0.0%)	4 (36.4%)
	1	0 (0.0%)	1 (9.1%)	3 (27.3%)	0 (0.0%)	4 (36.4%)
Total		0 (0.0%)	4 (36.4%)	7 (63.6%)	0 (0.0%)	11 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk

	Informational			
	High (= High)	Medium (>= Medium)	Low (>= Low)	Informational
https://cdn.jsdelivr.net	0 (0)	1 (1)	0 (1)	1 (2)
Site http://192.168.100.50:5000	0 (0)	3 (3)	3 (6)	3 (9)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	3 (27.3%)
Cross-Domain Misconfiguration	Medium	2 (18.2%)
Missing Anti-clickjacking Header	Medium	3 (27.3%)
Sub Resource Integrity Attribute Missing	Medium	2 (18.2%)
Cross-Domain JavaScript Source File Inclusion	Low	3 (27.3%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	2 (18.2%)
Total		11

Alert type	Risk	Count
X-Content-Type-Options Header Missing	Low	2 (18.2%)
Authentication Request Identified	Informational	1 (9.1%)
Retrieved from Cache	Informational	2 (18.2%)
Session Management Response Identified	Informational	5 (45.5%)
User Agent Fuzzer	Informational	3 (27.3%)
Total		11

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	3
Low	Warning		ZAP warnings logged - see the zap.log file for details	1
Low	Exceeded High	http:// 192.16 8.100. 50:500 0	Percentage of responses with status code 4xx	52 %

Level	Reason	Site	Description	Statistic
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://192.168.100.50:5000	Percentage of responses with status code 2xx	46 %
Info	Informational	http://192.168.100.50:5000	Percentage of responses with status code 3xx	14 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with content type text/css	9 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with content type text/html	90 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with method GET	81 %
Info	Informational	http://192.168.100.50:5000	Percentage of endpoints with method POST	18 %
Info	Informational	http://192.168.100.50:5000	Count of total endpoints	11

Level	Reason	Site	Description	Statistic
		8.100.50:5000		
Info	Informational	http://192.168.100.50:5000	Percentage of slow responses	7 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type application/javascript	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with content type text/css	50 %
Info	Informational	https://cdn.jsdelivr.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://cdn.jsdelivr.net	Count of total endpoints	2
Info	Informational	https://cdn.jsdelivr.net	Percentage of slow responses	27 %

Alerts

Risk=Medium, Confidence=High (2)

<http://192.168.100.50:5000> (2)

Content Security Policy (CSP) Header Not Set (1)

▼ GET <http://192.168.100.50:5000/>

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-693](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)

Alert description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/  
HTTP/1.1  
host: 192.168.100.50:5000
```


User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:01:56 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 2563
Vary: Cookie
Connection: close

► Response body (2563 bytes)

Solution

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Sub Resource Integrity Attribute Missing (1)

▼ GET http://192.168.100.50:5000/

Alert tags

- [CWE-345](#)
- [OWASP_2021_A05](#)

- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)
- POLICY_DEV_STD =

Alert description

The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/
HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:01:56 GMT
Content-Type: text/html;
charset=utf-8
```

Content-Length: 2563

Vary: Cookie

Connection: close

► Response body (2563 bytes)

Evidence

```
<link
href="https://cdn.jsdelivr.net/npm/b
ootstrap@5.3.3/dist/css/bootstrap.mi
n.css" rel="stylesheet">
```

Solution

Provide a valid integrity attribute to the tag.

Risk=Medium, Confidence=Medium (2)

<https://cdn.jsdelivr.net> (1)

Cross-Domain Misconfiguration (1)

▼ GET

<https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css>

Alert tags

- [OWASP 2021_A01](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2025_A01](#)
- [OWASP 2017_A05](#)
- [CWE-264](#)

Alert description

Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.

Other info

The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.

Request

▼ Request line and header section (410 bytes)

```
GET
https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css
HTTP/1.1
host: cdn.jsdelivr.net
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
Sec-Fetch-Dest: style
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: cross-site
Priority: u=2
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (1103 bytes)

```
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 13:01:57 GMT
Content-Type: text/css; charset=utf-8
Connection: keep-alive
access-control-allow-origin: *
access-control-expose-headers: *
timing-allow-origin: *
cache-control: public, max-age=31536000, s-maxage=31536000, immutable
cross-origin-resource-policy: cross-origin
x-content-type-options: nosniff
strict-transport-security: max-age=31536000; includeSubDomains; preload
x-jsd-version: 5.3.3
x-jsd-version-type: version
etag: W/"38d63-xawd7pYctZoEUlbsID9p4xeHL3w"
Report-To: {"group":"cf-nel","max_age":604800,"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=drJOgm%2FAD%2FJrhXBQTncZUTNEzCI8TONMJSpgguNN8ZLnP6KHJx%2Bwi90bU1utmNiAmtYSMYhCzJoIMD6lCJLyb6ZmivXYdkJpvEURJBkxeq%2FitbxEntTxymMmmmt%2BxB7vuP4%3D"}]}
x-served-by: cache-fra-etou8220150-FRA, cache-sin-wsat1880058-SIN
x-cache: HIT, HIT
vary: Accept-Encoding
alt-svc: h3=":443"; ma=86400
Nel: {"report_to":"cf-nel","success_fraction":0.01,"max_age":604800}
Age: 2972156
cf-cache-status: HIT
Server: cloudflare
CF-RAY: a2976e8f6ddba483-KUL
content-length: 232803
```

► Response body (232803 bytes)

Evidence

access-control-allow-origin: *

Solution

Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance).

Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

<http://192.168.100.50:5000> (1)

Missing Anti-clickjacking Header (1)

▼ GET <http://192.168.100.50:5000/>

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [CWE-1021](#)
- [SYSTEMIC](#)
- [WSTG-v42-CLNT-09](#)
- [OWASP 2017 A06](#)
- [OWASP 2025 A02](#)

Alert description

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Request**▼ Request line and header section (333 bytes)**

```
GET http://192.168.100.50:5000/  
HTTP/1.1  
host: 192.168.100.50:5000  
User-Agent: Mozilla/5.0 (X11; Linux  
x86_64; rv:128.0) Gecko/20100101  
Firefox/128.0  
Accept:  
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Connection: keep-alive  
Upgrade-Insecure-Requests: 1  
Priority: u=0, i
```

▼ Request body (0 bytes)**Response****▼ Status line and header section (189 bytes)**

```
HTTP/1.1 200 OK  
Server: Werkzeug/3.0.3 Python/3.12.3  
Date: Tue, 11 Aug 2026 13:01:56 GMT  
Content-Type: text/html;  
charset=utf-8  
Content-Length: 2563  
Vary: Cookie  
Connection: close
```

► Response body (2563 bytes)**Parameter**

x-frame-options

Solution

Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of

them is set on all web pages returned by your site/app.

If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Risk=Low, Confidence=High (1)

<http://192.168.100.50:5000> (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▼ GET <http://192.168.100.50:5000/static/css/style.css>

Alert tags

- [OWASP 2021 A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [OWASP 2017 A06](#)
- [WSTG-v42-INFO-02](#)
- [CWE-497](#)
- [OWASP 2025 A02](#)

Alert description

The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

Request

▼ Request line and header section (313 bytes)

GET
http://192.168.100.50:5000/static/css/style.css HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
Priority: u=2

▼ Request body (0 bytes)

Response

▼ Status line and header section (367 bytes)

HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:01:56 GMT
Content-Disposition: inline; filename=style.css
Content-Type: text/css; charset=utf-8
Content-Length: 763
Last-Modified: Thu, 30 Apr 2026 13:03:00 GMT
Cache-Control: no-cache
ETag: "1777554180.0-763-2936738339"
Date: Tue, 11 Aug 2026 13:01:56 GMT
Connection: close

▼ Response body (763 bytes)

```
body { background: #f7f7fb; }  
.hero { background: linear-  
gradient(135deg, #b00020, #e53935);  
}  
.blood-drop { font-size: 8rem;
```

```

filter: drop-shadow(0 12px 18px
rgba(0,0,0,.25)); }
.stat-card { background: #fff;
border-radius: 1rem; padding:
1.5rem; box-shadow: 0 .5rem 1.5rem
rgba(0,0,0,.07); border-left: 6px
solid #dc3545; }
.stat-card span { color: #6c757d;
display: block; }
.stat-card strong { font-size:
2.5rem; color: #b00020; }
.record-box { border-left: 4px
solid #dc3545; background: #fff5f5;
padding: .75rem; margin-bottom:
.75rem; border-radius: .5rem; }
.update-output { min-height: 240px;
white-space: pre-wrap; background:
#111827; color: #e5e7eb; padding:
1rem; border-radius: .75rem; }
.card { border-radius: 1rem; }
.btn { border-radius: .6rem; }

```

Evidence

Werkzeug/3.0.3 Python/3.12.3

Solution

Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.

Risk=Low, Confidence=Medium (2)<http://192.168.100.50:5000> (2)**Cross-Domain JavaScript Source File Inclusion (1)**▼ GET <http://192.168.100.50:5000/>**Alert tags**

- [OWASP 2025 A08](#)
- POLICY_QA_STD =
- POLICY_PENTEST =

- [SYSTEMIC](#)
- [OWASP 2021 A08](#)
- [CWE-829](#)
- POLICY_DEV_STD =

Alert description

The page includes one or more script files from a third-party domain.

Request

▼ Request line and header section (333 bytes)

```
GET http://192.168.100.50:5000/  
HTTP/1.1  
host: 192.168.100.50:5000  
User-Agent: Mozilla/5.0 (X11; Linux  
x86_64; rv:128.0) Gecko/20100101  
Firefox/128.0  
Accept:  
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8  
Accept-Language: en-US,en;q=0.5  
Connection: keep-alive  
Upgrade-Insecure-Requests: 1  
Priority: u=0, i
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (189 bytes)

```
HTTP/1.1 200 OK  
Server: Werkzeug/3.0.3 Python/3.12.3  
Date: Tue, 11 Aug 2026 13:01:56 GMT  
Content-Type: text/html;  
charset=utf-8  
Content-Length: 2563  
Vary: Cookie  
Connection: close
```

► Response body (2563 bytes)

Parameter	<code>https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/js/bootstrap.bundle.min.js</code>
Evidence	<code><script src="https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/js/bootstrap.bundle.min.js"></script></code>
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.

X-Content-Type-Options Header Missing (1)

▼ GET `http://192.168.100.50:5000/static/css/style.css`

Alert tags	▪ OWASP 2021 A05 ▪ POLICY_QA_STD = ▪ POLICY_PENTEST = ▪ SYSTEMIC ▪ CWE-693 ▪ OWASP 2017 A06 ▪ OWASP 2025 A02
-------------------	--

Alert description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
--------------------------	--

Other info	This issue still applies to error type pages (401, 403, 500, etc.) as those
-------------------	---

pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.

Request

▼ Request line and header section (313 bytes)

```
GET
http://192.168.100.50:5000/static/css
/style.css HTTP/1.1
host: 192.168.100.50:5000
User-Agent: Mozilla/5.0 (X11; Linux
x86_64; rv:128.0) Gecko/20100101
Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
Priority: u=2
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (367 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:01:56 GMT
Content-Disposition: inline;
filename=style.css
Content-Type: text/css; charset=utf-8
Content-Length: 763
Last-Modified: Thu, 30 Apr 2026
13:03:00 GMT
Cache-Control: no-cache
ETag: "1777554180.0-763-2936738339"
```

Date: Tue, 11 Aug 2026 13:01:56 GMT

Connection: close

▼ Response body (763 bytes)

```
body { background: #f7f7fb; }
.hero { background: linear-
gradient(135deg, #b00020, #e53935); }
.blood-drop { font-size: 8rem;
filter: drop-shadow(0 12px 18px
rgba(0,0,0,.25)); }
.stat-card { background: #fff;
border-radius: 1rem; padding:
1.5rem; box-shadow: 0 .5rem 1.5rem
rgba(0,0,0,.07); border-left: 6px
solid #dc3545; }
.stat-card span { color: #6c757d;
display: block; }
.stat-card strong { font-size:
2.5rem; color: #b00020; }
.record-box { border-left: 4px solid
#dc3545; background: #fff5f5;
padding: .75rem; margin-bottom:
.75rem; border-radius: .5rem; }
.update-output { min-height: 240px;
white-space: pre-wrap; background:
#111827; color: #e5e7eb; padding:
1rem; border-radius: .75rem; }
.card { border-radius: 1rem; }
.btn { border-radius: .6rem; }
```

Parameter

x-content-type-options

Solution

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform

MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

Risk=Informational, Confidence=High (1)

<http://192.168.100.50:5000> (1)

Authentication Request Identified (1)

▼ POST <http://192.168.100.50:5000/staff/login>

Alert tags

**Alert
description**

The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

Other info

userParam=username

userValue=ZAP

passwordParam=password

referer=<http://192.168.100.50:5000/staff/login>

csrfToken=csrf_token

Request

▼ Request line and header section (499 bytes)

POST

<http://192.168.100.50:5000/staff/log>

```
in HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT
10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/141.0.0.0
Safari/537.36
pragma: no-cache
cache-control: no-cache
content-type: application/x-www-
form-urlencoded
referer:
http://192.168.100.50:5000/staff/log
in
content-length: 128
Cookie:
session=eyJjc3JmX3Rva2VuIjoiMTI1MzIz
ZjVjNTM2YjIwMGI0OGI5NDJhODkxNTlkN2E3
NjUzYjMyYSJ9.ansdXQ.GV3PvYmNavSncssR
9EH0QSTaxrA
```

▼ Request body (128 bytes)

```
username=ZAP&password=ZAP&csrf_token
=IjI5YzBjNjU2ZTY5NDBiOGUxODM5ODE5MDM
yYjAyMTVkJjQ1Mzg2NWJi.ansdXQ.hN4Kkwp
pxwgc8ocWWS-gHK7EYKo
```

Response

▼ Status line and header section (197 bytes)

```
HTTP/1.1 400 BAD REQUEST
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:02:21 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 120
Vary: Cookie
Connection: close
```

▼ Response body (120 bytes)


```
<!doctype html>
<html lang=en>
<title>400 Bad Request</title>
<h1>Bad Request</h1>
<p>The CSRF tokens do not match.</p>
```

Parameter username

Evidence password

Solution This is an informational alert rather than a vulnerability and so there is nothing to fix.

Risk=Informational, Confidence=Medium (3)

<https://cdn.jsdelivr.net> (1)

Retrieved from Cache (1)

▼ GET

<https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css>

Alert tags

- [OWASP 2025 A07](#)
- [CWE-525](#)
- POLICY_PENTEST =
- [OWASP 2021 A07](#)
- [SYSTEMIC](#)
- [WSTG-v42-ATHN-06](#)
- [OWASP 2017 A02](#)

Alert description

The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the

caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

Request

▼ Request line and header section (410 bytes)

```
GET
https://cdn.jsdelivr.net/npm/bootstrap@5.3.3/dist/css/bootstrap.min.css
HTTP/1.1
host: cdn.jsdelivr.net
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/css,*/*;q=0.1
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
Referer: http://192.168.100.50:5000/
Sec-Fetch-Dest: style
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: cross-site
Priority: u=2
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (1103 bytes)

```
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2026 13:01:57 GMT
Content-Type: text/css; charset=utf-8
Connection: keep-alive
access-control-allow-origin: *
access-control-expose-headers: *
timing-Allow-Origin: *
cache-control: public, max-
```

```
age=31536000, s-maxage=31536000,
immutable
cross-origin-resource-policy: cross-
origin
x-content-type-options: nosniff
strict-transport-security: max-
age=31536000; includeSubDomains;
preload
x-jsd-version: 5.3.3
x-jsd-version-type: version
etag: W/"38d63-
xawd7pYctZoEUlbsID9p4xeHL3w"
Report-To: {"group":"cf-
nel","max_age":604800,"endpoints":
[{"url":"https://a.nel.cloudflare.com
/report/v4?
s=drJOgm%2FAD%2FJrhXBQTncZUTNEzCI8TON
MJSpgguNN8ZLnP6KHJx%2Bwi90bU1utmNiAm
tYSMYhCzJoIMD6lCJLyb6ZmivXYdkJpvEURJB
kxeq%2FitbxEntTxymMmmmt%2BxB7vuP4%3D"}
]}
x-served-by: cache-fra-etou8220150-
FRA, cache-sin-wsat1880058-SIN
x-cache: HIT, HIT
vary: Accept-Encoding
alt-svc: h3=":443"; ma=86400
Nel: {"report_to":"cf-
nel","success_fraction":0.01,"max_age
":604800}
Age: 2972156
cf-cache-status: HIT
Server: cloudflare
CF-RAY: a2976e8f6ddba483-KUL
content-length: 232803
```

► Response body (232803 bytes)

Evidence

HIT

Solution

Validate that the response does not contain sensitive, personal or user-

specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

<http://192.168.100.50:5000> (2)

Session Management Response Identified (1)

▼ GET <http://192.168.100.50:5000/staff/login>

Alert tags

Alert description

The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

Other info

cookie:session

Request

▼ Request line and header section (287 bytes)

```
GET
http://192.168.100.50:5000/staff/login HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache
cache-control: no-cache
referer: http://192.168.100.50:5000
```

▼ Request body (0 bytes)

Response

▼ Status line and header section (354 bytes)

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:02:21 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 2081
Vary: Cookie
Set-Cookie:
session=eyJjc3JmX3Rva2VuIjoimjlmMGM2
NTZlNjk0MGI4ZTE4Mzk4MTkwMzJiMDIxNWRI
NDUzODY1YiJ9.ansdXQ.uIA3rJgLFHPaPE0M
40HZffwLluw; HttpOnly; Path=/;
SameSite=Lax
Connection: close
```

► Response body (2081 bytes)

Parameter	session
Evidence	session
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.

User Agent Fuzzer (1)

▼ GET http://192.168.100.50:5000/donor/register

- | | |
|-------------------|---|
| Alert tags | <ul style="list-style-type: none">■ CUSTOM_PAYLOADS =■ POLICY_PENTEST =■ SYSTEMIC |
|-------------------|---|

Alert description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
--------------------------	--

Request	▼ Request line and header section (230 bytes)
----------------	---

```
GET
http://192.168.100.50:5000/donor/register HTTP/1.1
host: 192.168.100.50:5000
user-agent: Mozilla/4.0
(compatible; MSIE 8.0; Windows NT
6.1)
pragma: no-cache
cache-control: no-cache
referer: http://192.168.100.50:5000/
```

▼ Request body (0 bytes)

Response**▼ Status line and header section (354 bytes)**

```
HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.12.3
Date: Tue, 11 Aug 2026 13:05:35 GMT
Content-Type: text/html;
charset=utf-8
Content-Length: 2785
Vary: Cookie
Set-Cookie:
session=eyJjc3JmX3Rva2VuIjoizjI4Y2Zm
ZGZiMmE3YjIwNzQ3OTdkODFkMTM3YmM4M2M5
Y2YwNTZhYSJ9.anseHw.Dvoh2XQIFuPi390F
2RKure04fOU; HttpOnly; Path=/;
SameSite=Lax
Connection: close
```

► Response body (2785 bytes)**Parameter**

Header User-Agent

Attack

Mozilla/4.0 (compatible; MSIE 8.0;
Windows NT 6.1)

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Cross-Domain Misconfiguration

Source	raised by a passive scanner (Cross-Domain Misconfiguration)
CWE ID	264
WASC ID	14
Reference	▪ https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
--------	---

CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security-Headers

Authentication Request Identified

Source	raised by a passive scanner (Authentication Request Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

Retrieved from Cache

Source	raised by a passive scanner (Retrieved from Cache)
CWE ID	525
Reference	▪ https://datatracker.ietf.org/doc/html/rfc7234 ▪ https://datatracker.ietf.org/doc/html/rfc7231 ▪ https://www.rfc-editor.org/rfc/rfc9110.html

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg